

Investigative report on the threat group: Scattered Spider

Dennis Kalinin

Robert Morris University

Cyber Intelligence Masters Capstone

May 7, 2026

Executive Summary

Scattered Spider is best assessed as a distinct, financially motivated cyber threat actor whose comparative advantage is not a proprietary malware family or a novel software exploit, but extraordinary success in socially engineering enterprise identity, helpdesk, support-desk, and trusted-vendor workflows. The group's recurrent pattern is to exploit people and process before it exploits technology: obtain enough personnel context to sound legitimate, manipulate password-reset or MFA-enrollment procedures, seize authenticated access, and then pivot rapidly into cloud data, virtualization infrastructure, backup environments, or extortion-sensitive business systems. The clearest public evidence for that assessment comes from the July 2025 allied Scattered Spider advisory, earlier Okta reporting on Scatter Swine/Oktapus, and subsequent incident-response reporting from frontline defenders.

The most defensible attribution model is that Scattered Spider is real and analytically useful as a distinct cluster, but it operates inside a wider English-speaking cybercrime ecosystem often linked in public reporting to "The Com." That model explains the recurring overlap in open-source reporting with labels such as UNC3944, Octo Tempest, Scatter Swine, Storm-0875, and Muddled Libra, while also explaining why narratives involving ShinyHunters, LAPSUS\$, and later coalition or branding claims should be treated as overlap, collaboration, or ecosystem adjacency rather than as evidence that all such actors form one fixed organization.

Scattered Spider's strategic significance is its evolution from identity-centric access operations into enterprise extortion and, by 2025, more frequent ransomware-enabled disruption. Public reporting indicates an arc from telecom- and SIM-swap-linked tactics to large corporate intrusions, followed by more direct operational impact against hotel, retail, and transport environments and growing linkage to DragonForce and ESXi-focused encryption. That evolution

matters because it shows how a threat actor rooted in consumer-style fraud and account takeover can mature into a business-interruption threat capable of imposing nine-figure losses, long-lived service degradation, and significant secondary risk through third parties and SaaS platforms.

The most probative case studies remain the 2023 intrusions affecting MGM Resorts International and Caesars Entertainment, the 2024 intrusion affecting Transport for London, the 2024 Snowflake-related mass extortion environment, and the 2025 disruption affecting Marks & Spencer. Together, these incidents show a consistent operational logic: compromise trust, subvert identity, persist using either newly enrolled authenticators or legitimate administration tools, move toward high-value data or hypervisor environments, and convert access into leverage against confidentiality, availability, or both.

Public law-enforcement action between 2024 and 2026 has materially increased the cost of participation for Scattered Spider-linked actors, but it has not removed the underlying threat model. The best forecast is continued sectoral targeting waves, periodic short-term slowdowns after arrests, persistent imitation by adjacent financially motivated actors, and enduring organizational vulnerability wherever help-desk procedures, contractor trust relationships, and SaaS identity governance remain weak.

Introduction, Scope, and Method

This report is written as an intelligence-style assessment rather than a conventional narrative term paper. Its purpose is not merely to recount incidents but to answer four analytic questions: what Scattered Spider is, how it operates, why it matters strategically, and what organizations can do to reduce the specific risks created by its tradecraft. The analysis privileges

primary and quasi-primary material: government advisories, official law-enforcement announcements, company regulatory disclosures, official victim statements, and incident-response reporting from established defense organizations. Where a point depends primarily on source-based media reporting rather than on the victim's own disclosure, the report states that limitation directly.

The underlying draft record supplied by the user already reflected several analytically sound corrections that this final synthesis preserves: Scattered Spider should be treated as distinct from LAPSUS\$ except where overlap or ecosystem relationships are specifically under discussion; attribution language should distinguish evidence from inference; and the core of the actor's operational value lies in social engineering and identity compromise rather than in a single named malware tool. This final report adopts those corrections and extends them into a fuller attribution and operational model.

A central methodological challenge is alias inflation. Public reporting on Scattered Spider often blends threat-intelligence naming conventions, law-enforcement language, media shorthand, actor self-branding, and ecosystem rumor into a single narrative. That can flatten important distinctions. This report therefore separates three levels of analytic confidence. High confidence is reserved for claims supported by official advisories, formal corporate disclosures, or direct law-enforcement actions. Moderate confidence is used where multiple credible sources align but the public record is still incomplete. Low to moderate confidence is used for coalition narratives, actor-brand claims, or inferences about structure that are plausible but not yet strongly corroborated.

The report also proceeds from an important negative finding: not every credential-driven, SaaS-heavy, data-extortion campaign is Scattered Spider. Public reporting on the 2024

Snowflake customer extortion wave, for example, tracked a separate cluster, UNC5537, and explicitly stated that the incidents did not result from a breach of Snowflake itself. That distinction matters because Scattered Spider's target logic clearly includes Snowflake and similar SaaS environments, but analytical rigor requires separating "similar method" from "same actor" unless the evidence supports a merge.

Threat Landscape, Attribution, and Analytic Judgment

The current threat landscape supports a simple core judgment: Scattered Spider is a distinct actor cluster with recurring behavior, but not a rigid, permanently fixed cartel. Public and private tracking aliases converge around the same operational family even when nomenclature differs. The July 2025 allied advisory links Scattered Spider to UNC3944, Scatter Swine, Oktapus, Octo Tempest, Storm-0875, and Muddled Libra, among others. That degree of convergence is stronger than would be expected if the label were merely journalistic shorthand. At the same time, the surrounding ecosystem evidence is too fluid to justify describing Scattered Spider as a tightly centralized organization with stable membership and command structures. The more accurate model is a recognizable core cluster embedded in a looser criminal environment.

Open-source and law-enforcement reporting strongly support the proposition that Scattered Spider exists within a broader English-speaking youth-heavy cybercrime environment often associated with "The Com." The 2025 Federal Bureau of Investigation alert on Hacker Com describes a subset of The Com as a rising threat to youth online and associates that ecosystem with SIM swapping, phishing, cryptocurrency theft, ransomware, credential theft,

extortion, doxing, and harassment. That framing is analytically important because it explains why operator overlap, temporary collaboration, and skill-sharing occur so frequently in investigations connected to Scattered Spider. It also helps explain why arrests disrupt specific nodes without collapsing the overall threat model.

Attribution Summary Table

Label or relationship	Public reporting context	Analytic assessment
Scattered Spider	Widely used public name in government and media reporting	Distinct and useful umbrella label for an identity-centric criminal cluster
UNC3944	Industry tracking label associated with the same operations family	Strong overlap; best treated as substantially co-referential in most reporting
Octo Tempest	Microsoft tracking label for overlapping activity	Strong overlap; useful when relying on Microsoft reporting
Scatter Swine / Oktapus	Earlier Okta-centered or campaign-specific labeling	Historically relevant precursor or overlapping naming layer
ShinyHunters	Separate criminal brand appearing in extortion and SaaS-theft reporting	Ecosystem overlap and possible collaboration, but not identical by default

Label or relationship	Public reporting context	Analytic assessment
LAPSUS\$	Distinct historic actor with partial cultural or ecosystem overlap in public reporting	Do not collapse into Scattered Spider except when discussing adjacency or collaboration claims
DragonForce	Ransomware operation reportedly linked to recent Scattered Spider activity	Best treated as a partner, service provider, or impact-enabler rather than as synonymous with Scattered Spider

The table above synthesizes the most stable cross-source attribution picture. It reflects the allied advisory, Okta’s historical work on Scatter Swine/Oktapus, Microsoft’s Octo Tempest reporting, GTIG’s later SaaS-extortion tracking, and low-confidence but analytically relevant coalition narratives.

ACH Assessment

The report evaluated three competing hypotheses.

Hypothesis A: Scattered Spider is a distinct actor cluster embedded in a wider criminal ecosystem.

Hypothesis B: Scattered Spider has effectively merged into a durable cartel with LAPSUS\$, ShinyHunters, and related brands.

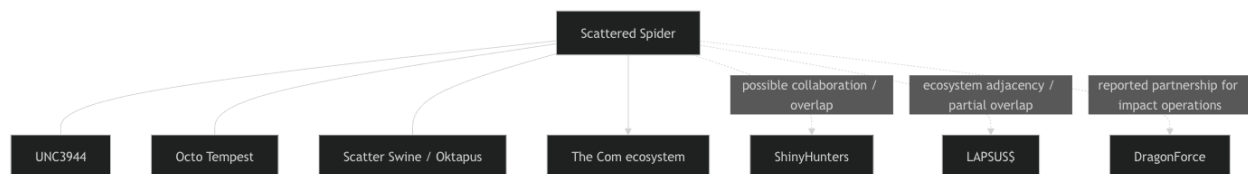
Hypothesis C: Scattered Spider is mostly a media catch-all for unrelated identity-focused extortion actors.

Evidence question	Hypothesis A	Hypothesis B	Hypothesis C
Consistent tradecraft across major incidents	Strongly consistent	Consistent	Weakly consistent
Alias convergence across government and industry reporting	Strongly consistent	Partly consistent	Inconsistent
Youth-heavy English-speaking ecosystem evidence	Strongly consistent	Consistent	Consistent
Stable proof of formal merged hierarchy	Not required	Required but weakly supported	Not required
Ability to explain overlap with adjacent brands	Strongly consistent	Strongly consistent	Partly consistent
Ability to explain why similar tactics persist after arrests	Strongly consistent	Consistent	Consistent
Alignment with public law-enforcement case structure	Strongly consistent	Partly consistent	Weakly consistent

On balance, Hypothesis A best fits the record. Hypothesis B remains plausible as an episodic collaboration model, but the public evidence is still too thin to support a conclusion of a durable merged organization. Hypothesis C fails to explain why government and private defenders continue to observe a sufficiently coherent operational profile to track the actor across sectors and time.

Relationship Diagram

The strongest relationships in the diagram are the alias-level links among Scattered Spider, UNC3944, Octo Tempest, and Scatter Swine/Oktapus. The relationships to The Com, ShinyHunters, LAPSUS\$, and DragonForce are real but analytically different in kind: they describe ecosystem context, partial overlap, or reported collaboration rather than identity.



Confidence Assessment

Confidence is high that Scattered Spider represents a distinct and analytically useful threat-actor designation rather than a purely media-generated label. Multiple independent cybersecurity vendors, government agencies, law-enforcement investigations, and incident-response engagements have consistently identified recurring operational behaviors associated with the group. These include heavy reliance on social engineering, help-desk impersonation, SIM swapping, MFA fatigue attacks, identity-provider compromise, and targeting of large enterprise environments. The consistency of these tactics across incidents involving organizations such as MGM Resorts, Caesars Entertainment, and other major enterprises supports the conclusion that Scattered Spider reflects a recognizable operational cluster with shared behavioral characteristics.

Confidence is moderate that Scattered Spider is best understood as a decentralized and continuously reforming cybercriminal ecosystem rather than a rigid hierarchical organization.

Available evidence strongly suggests fluid membership, shifting aliases, and collaboration across broader online criminal communities commonly associated with “The Com.” Arrests and indictments have not fully disrupted operational activity, indicating that the ecosystem can regenerate through recruitment, rebranding, and informal partnerships. However, the precise internal structure, leadership mechanisms, and long-term coordination processes remain unclear due to the inherently fragmented and anonymous nature of the environment. This limits the ability to make definitive judgments regarding organizational hierarchy.

Confidence is moderate that DragonForce-linked infrastructure or operational collaboration has appeared in some recent Scattered Spider-associated activity. Reporting and incident analysis indicate potential overlap in tooling, extortion methods, or partnership behavior within broader ransomware and extortion ecosystems. However, the evidence currently available does not conclusively demonstrate a permanent or formally integrated operational relationship. It remains possible that these interactions reflect temporary cooperation, shared affiliates, or opportunistic partnerships common within modern cybercriminal marketplaces rather than a stable alliance.

Confidence is low to moderate that the reported “Trinity of Chaos” narrative represents a durable merger between major threat-actor groups. While there are observable overlaps between Scattered Spider, LAPSUS\$, ShinyHunters, and related ecosystem participants, much of the reporting remains based on fragmented intelligence, underground-community narratives, or external analytical interpretation. Cybercriminal actors frequently exaggerate affiliations, rebrand operations, or intentionally blur attribution lines to increase notoriety and complicate investigations. As a result, it is more likely that the “Trinity of Chaos” concept reflects

temporary coalition behavior, shared ecosystem participation, branding narratives, or observer over-aggregation rather than a single permanently unified cybercriminal organization.

Operational Analysis, Social Engineering, Infrastructure, and MITRE ATT&CK

Scattered Spider's operational center of gravity is identity compromise through staged social engineering. The actor's campaigns are notable not simply because they use phishing, but because they use layered, context-rich impersonation. Reporting indicates that actors first collect employee names, phone numbers, usernames, and role-specific information from open sources, then study internal support procedures, call help desks to learn reset logic, and finally impersonate either the employee or the support function during the decisive interaction. In many cases, the goal is not just password theft but the enrollment of attacker-controlled MFA devices or the reset of recovery methods that enable persistent access even after the first credential changes. The result is a human-process intrusion chain rather than a pure credential-capture event.

Once authenticated, Scattered Spider tends to avoid noisy custom tooling when legitimate administration paths will suffice. Public reporting repeatedly references remote monitoring and management tools, cloud consoles, virtualization management systems, email, collaboration platforms, SharePoint repositories, identity-provider portals, and data platforms. This choice matters because it reduces the actor's need for bespoke malware and increases dwell time under the cover of normal administrative behavior. It also complicates detection because many of the relevant events are "valid account, invalid purpose" rather than overt exploit signatures.

A particularly important pattern in later reporting is the move toward “business operating system” infrastructure: cloud identity, SaaS data repositories, vCenter, ESXi, backup control planes, and high-value data warehouses. The July 2025 allied advisory explicitly notes actor interest in Snowflake access and large-volume querying, while multiple public accounts link later operations to DragonForce and VMware ESXi encryption. Operationally, this shows maturation. Rather than treating data theft and ransomware as separate schools of crime, Scattered Spider appears increasingly capable of chaining them: obtain identity, seize enterprise control, exfiltrate strategically useful data, and if necessary, deny recovery or degrade services to increase bargaining power.

MITRE ATT&CK Mapping

		Representative	
ATT&CK phase	Observed Scattered Spider	ATT&CK	Why it matters
	behavior	techniques	operationally
Reconnaissance	Gathering employee	T1589, T1593.001,	Enables credible
	names, roles, phone	T1594, T1597.002	impersonation and
	numbers, and support		tailored pretexting
	patterns		
Resource	Registering impersonation	T1583.001, T1585	Supports phishing,
development	infrastructure and staging		callback fraud, and
	accounts		account resets

ATT&CK phase	Observed Scattered Spider behavior	Representative	
		ATT&CK techniques	Why it matters operationally
Initial access	SMS phishing, voice phishing, help-desk impersonation, vendor-trust abuse	T1566, T1566.004, T1660, T1199	Converts social engineering into enterprise foothold
Credential access	Harvesting or resetting credentials; intercepting or manipulating MFA	T1110, T1556.006	Creates durable identity control, not just one-time login
Persistence	Registering attacker-controlled authenticators or creating new access paths	T1556.006, T1098	Makes eviction harder after initial detection
Privilege escalation	Using newly reset accounts, admin workflows, or legitimate tools	T1078, T1134	Raises control without noisy malware dependencies
Discovery	Searching email, SharePoint, code repos, cloud consoles, vCenter, Snowflake	T1087, T1083, T1018, T1046	Identifies extortion-critical data and impact infrastructure

ATT&CK phase	Observed Scattered Spider behavior	Representative	
		ATT&CK techniques	Why it matters operationally
Lateral movement	RMM and remote administration paths; trust relationships	T1219, T1021	Preserves stealth and speeds enterprise expansion
Collection and exfiltration	Large query activity, staging to cloud storage, MEGA, or S3	T1537, T1567	Converts access into monetizable leverage
Impact	ESXi encryption, ransomware deployment, service disruption	T1486, T1490	Creates deadline pressure and operational pain

This table aligns the public record into ATT&CK language suitable for academic or professional appendix use. Public descriptions differ in exact detail by incident, but the dominant pattern across sources is stable enough to justify this mapping.

Infrastructure and OPSEC

Public reporting indicates that Scattered Spider often prefers infrastructure that supports impersonation, mobility, and plausible deniability over bespoke malware innovation. Relevant

elements include disposable domains, attacker-created identities, proxy or VPN usage, remote-management platforms, cloud storage for staging or exfiltration, and social media or messaging accounts used to reinforce false personas. The actor's OPSEC strength lies less in perfect secrecy than in blending into enterprise administrative systems and relying on rapid action after access is gained. It is also notable that the actor appears willing to exploit third-party support channels and external vendors, which allows it to externalize risk and bypass some of the stronger identity controls inside the victim organization itself.

A critical operational implication follows from that pattern: organizations that focus primarily on malware telemetry will underperform against Scattered Spider because the actor's most important "tools" are trust, speech, procedure, and valid credentials. In that sense, Scattered Spider is not merely another extortion actor. It is a stress test for whether identity governance, vendor assurance, service-desk discipline, and SaaS monitoring are treated as core security functions.

Incident Case Studies, Financial Model, and Cryptocurrency Assessment

MGM Resorts and Caesars Entertainment

The casino intrusions remain the foundational public Scattered Spider case studies because they made visible the actor's ability to convert identity compromise into enterprise-scale operational and extortion consequences. Source-based reporting from Reuters on MGM attributed the incident to Scattered Spider. MGM's October 2023 SEC filing then confirmed that it shut down certain systems after identifying a cybersecurity issue, suffered material operational

disruption in its U.S. operations, and estimated approximately \$100 million in negative impact to September EBITDAR. The filing also confirmed that criminals obtained certain personal information for some customers who had transacted before March 2019.

Caesars provided a clearer official view of access mechanics. Its September 2023 filing states that the incident resulted from a social-engineering attack on an outsourced IT support vendor and that an unauthorized actor acquired a copy of the loyalty-program database containing driver's-license or Social Security number data for a significant number of members. The public narrative around Caesars became especially significant because it illustrated a different outcome from MGM: the same broad identity-centric intrusion logic, but a far smaller visible disruption to front-end operations. That contrast matters because it shows that Scattered Spider-like operations are not intrinsically “ransomware only” or “disruption only.” They are adaptable extortion operations, and impact depends on what leverage is most valuable in each environment.

Together, MGM and Caesars established the public archetype of the actor: exploit outsourced or help-desk processes, use legitimate pathways once inside, move quickly, and convert access into either visible business interruption or data-based extortion depending on what will generate the best result. They also pushed identity-focused social engineering into the center of enterprise threat discourse. Before these cases, many organizations still treated vishing and reset fraud as relatively peripheral compared with software-exploit-driven intrusions. After these cases, that distinction became much harder to sustain.

Transport for London

The 2024 intrusion affecting Transport for London showed that Scattered Spider-style operations translate effectively into public-service and transport environments. TfL stated that it identified suspicious activity on September 1, 2024, took action to contain the incident, and later confirmed that certain customer data had been accessed, including names, contact details, and, for a limited subset of customers, Oyster refund data that could include banking information. TfL's September 12 update said around 5,000 customers would be contacted regarding possible exposure of bank account numbers and sort codes. Subsequent public updates make clear that service restoration was protracted, with all affected fares-related services not fully restored until December 2024. TfL later reported that the ICO closed the matter in February 2025 without regulatory action, while the criminal investigation continued.

Analytically, TfL matters because it demonstrates three points. First, identity-driven intrusion chains can affect not only private-sector consumer businesses but also transport-system digital services with public-facing reliability consequences. Second, the incident reinforces that Scattered Spider-style tradecraft can impose long-tail restoration burdens even without the most catastrophic ransomware outcome. Third, public-sector and quasi-public organizations are not protected by mission type; if the identity plane and support processes are exposed, the same human-centered attack logic applies.

Snowflake-Related Activity

Snowflake occupies a special place in the Scattered Spider analysis because it is clearly relevant to the actor's targeting logic, but not every Snowflake-related extortion event should be attributed directly to Scattered Spider. Mandiant's June 2024 reporting on the Snowflake

customer extortion campaign explicitly tracked the activity as UNC5537 and stated that the incidents did not result from a breach of Snowflake's environment. Instead, investigated cases derived from compromised customer credentials, often linked to prior infostealer activity and frequently lacking MFA. That finding is important because it demonstrates how fragile identity controls around SaaS data platforms can create mass extortion opportunities even without a platform compromise.

At the same time, the allied Scattered Spider advisory states that recent actors search aggressively for a target organization's Snowflake access and may run large numbers of queries immediately after compromise. The correct synthesis is therefore narrower and stronger than a blanket merger claim. Snowflake is clearly part of Scattered Spider's objective set and extortion logic, but the 2024 UNC5537 campaign should be treated as analytically adjacent rather than conclusively identical unless a case-specific evidentiary bridge is available. That distinction is exactly the kind of analytical discipline needed to prevent ecosystem-level confusion from contaminating case attribution.

Marks & Spencer and the DragonForce Linkage

The 2025 incident affecting Marks & Spencer is the clearest public illustration of Scattered Spider's evolution into a hybrid extortion-and-disruption threat. Reporting from Reuters on May 19, 2025, stated that M&S had estimated the cyber incident would reduce operating profit by about £300 million and had already suspended online clothing orders. Later Reuters reporting stated that the intrusion involved social engineering against a third-party contractor and that at least two Tata Consultancy Services employee logins were reportedly used in the breach. A further Reuters report indicated that M&S leadership told lawmakers the

ransomware operation behind the attack was believed to be DragonForce and that loosely aligned parties appeared to have worked together.

This matters for two reasons. First, it is the clearest public case linking a Scattered Spider-style access model to DragonForce-associated impact activity. Second, the phrase “loosely aligned parties” is analytically valuable because it fits the broader ecosystem model better than a simple “same group” formulation. In practical terms, the case suggests division of labor or opportunistic partnering: an actor skilled in social engineering and identity compromise can either deploy its own impact capability or combine with a ransomware operation that specializes in encryption and extortion mechanics. Either way, the defensive consequence is the same. Once identity compromise reaches virtualization or recovery infrastructure, the victim’s options deteriorate quickly.

Financial and Extortion Model

Scattered Spider’s financial logic appears to rest on flexibility and opportunistic monetization rather than adherence to a single operational model. Unlike traditional ransomware groups that depend almost entirely on encryption-based extortion, Scattered Spider demonstrates the ability to generate value through multiple pathways depending on the target environment, the level of access obtained, and the strategic leverage available after compromise. This adaptive financial approach significantly increases the group’s operational resilience because failed monetization in one area does not necessarily prevent profit generation through another method.

The group has demonstrated the ability to extract value through direct theft, data extortion, business-interruption pressure, cryptocurrency theft, access brokerage, and

partnerships with broader extortion or ransomware ecosystems. Public law-enforcement investigations have linked individuals associated with Scattered Spider and related communities to multi-million-dollar cryptocurrency theft operations, while major victim disclosures involving MGM Resorts, Caesars Entertainment, and other enterprises illustrate how identity compromise alone can generate enormous downstream financial consequences. Even in situations where public reporting does not confirm a ransom payment, the operational disruption, reputational damage, regulatory exposure, and recovery costs imposed on victim organizations can still create substantial strategic leverage for attackers.

A defining strength of this model is that Scattered Spider does not require every intrusion to escalate into a traditional ransomware detonation to remain profitable. Once privileged access is established, the group can evaluate multiple monetization options simultaneously. In some cases, sensitive data can be exfiltrated and used for extortion. In others, stolen credentials or persistent access may be sold to affiliated threat actors within broader cybercriminal marketplaces. In high-value enterprise environments, simply disrupting operations or threatening public disclosure may generate sufficient pressure to force negotiations. This flexibility allows the group to dynamically select the monetization strategy most likely to maximize financial return while minimizing operational risk.

The emphasis on identity compromise also reduces operational cost compared to malware-heavy cybercriminal operations. Because Scattered Spider relies heavily on social engineering, credential theft, legitimate administrative tools, and cloud-service abuse, the group avoids many of the development and maintenance costs associated with custom ransomware or sophisticated exploit chains. This creates a comparatively efficient criminal model where human

manipulation and access abuse generate disproportionate financial impact. In effect, the group converts ordinary business processes and trust relationships into monetizable assets.

Cryptocurrency and Laundering Assessment

The public record clearly establishes that cryptocurrency is central to the Scattered Spider-linked enforcement and monetization picture, although the currently available open-source evidence does not yet expose a laundering architecture with the same level of transparency documented in some long-established ransomware cartels. Department of Justice disclosures indicate that Tyler Buchanan allegedly stole at least \$8 million in cryptocurrency assets, while Noah Urban was ordered to forfeit approximately \$4.8 million connected to cybercriminal activity. Additional DOJ allegations involving Talha Jubair referenced participation in activity associated with more than \$115 million in ransom payments and extortion-related transactions. Collectively, these figures strongly support a high-confidence assessment that cryptocurrency functions as the primary financial infrastructure enabling Scattered Spider-linked operations.

What remains less clear is the exact operational structure of the laundering process itself. Public indictments and press releases focus primarily on criminal conduct, victim impact, extortion magnitude, and conspiracy allegations rather than detailed blockchain tracing methodologies or complete cash-out mechanisms. As a result, confidence remains moderate regarding the specific laundering chain, intermediary services, and financial-routing techniques employed after extortion payments or theft proceeds are received. Nevertheless, enough

behavioral indicators exist to support several defensible analytical conclusions about how cryptocurrency likely supports the ecosystem operationally.

The most likely assessment is that Scattered Spider-linked actors rely on layered wallet movement, intermediary transfer chains, and broader cybercriminal financial services to obscure transaction origin and complicate attribution. Rather than immediately cashing out funds through a single exchange or identifiable endpoint, actors likely disperse assets across multiple wallets, services, or blockchain environments to fragment the financial trail. This behavior aligns with common laundering techniques observed across ransomware and extortion ecosystems, where operational security depends heavily on reducing direct traceability between victim payments and final withdrawal points.

The decentralized nature of Scattered Spider also suggests that cryptocurrency handling may not occur through one centralized treasury or leadership-controlled financial structure. Instead, funds may move through multiple participants, affiliates, or ecosystem partners depending on the operational role performed during an intrusion. Individuals specializing in access operations, extortion negotiations, SIM swapping, or account compromise may receive separate distributions or percentages of criminal proceeds. This decentralized financial behavior mirrors the broader organizational structure associated with “The Com” ecosystem and other loosely connected cybercriminal communities where collaboration occurs through temporary operational partnerships rather than permanent command hierarchies.

Timeline of Public Evolution

Scattered Spider first gained broader public attention through activity associated with the “Oktapus” and related credential-harvesting campaigns targeting telecommunications and technology organizations. During this period, the group demonstrated a strong reliance on phishing, SIM swapping, MFA fatigue attacks, and help-desk impersonation rather than sophisticated malware development. Analysts began identifying behavioral overlap between Scattered Spider, UNC3944, and online communities associated with “The Com,” highlighting the rise of younger, English-speaking cybercriminal actors focused heavily on identity compromise and account takeover operations

2023: MGM Resorts and Caesars Entertainment Breaches

The breaches affecting MGM Resorts and Caesars Entertainment marked a major turning point in public awareness of Scattered Spider. These incidents demonstrated how social engineering against IT support and identity-management workflows could produce enterprise-wide operational disruption. Attackers reportedly leveraged help-desk impersonation techniques to gain privileged access, leading to outages impacting hotel booking systems, casino operations, and internal enterprise services. The incidents elevated identity-focused attacks from a technical cybersecurity issue to a board-level business risk involving operational continuity, reputational damage, and extortion exposure.

2024: Expansion Into Broader SaaS and Infrastructure Targeting

By 2024, concern surrounding Scattered Spider expanded beyond hospitality and telecommunications into cloud infrastructure, SaaS providers, and large-scale enterprise identity systems. The Transport for London (TfL) incident reinforced fears that identity-centric attacks could affect critical public infrastructure and transportation services. During the same period,

cybersecurity reporting increasingly linked Scattered Spider activity to a wider extortion ecosystem involving cloud-platform abuse, credential theft, and SaaS exploitation. Analysts observed that the group was becoming more operationally flexible, focusing on trusted enterprise services rather than relying on traditional malware deployment.

2024: U.S. Criminal Charges and Increased Law-Enforcement Attention

U.S. law-enforcement agencies filed charges against several individuals allegedly connected to Scattered Spider operations, providing additional insight into the group's decentralized and youth-driven structure. Investigations suggested that some members operated from Western countries including the United States and United Kingdom, differing from the traditional geographic profile associated with many earlier cybercriminal organizations. These indictments also reinforced the assessment that Scattered Spider functioned more as a loosely connected ecosystem than a rigid hierarchy, with members collaborating across online platforms and rapidly shifting aliases or operational roles

2025: Marks & Spencer and DragonForce Linkage

The disruption affecting Marks & Spencer in 2025 expanded the public narrative surrounding Scattered Spider by demonstrating continued operational resilience despite arrests and public exposure. Reporting also introduced discussions of possible partnerships or operational overlap with DragonForce-related activity, suggesting a growing trend of temporary alliances between extortion-focused cybercriminal groups. This period highlighted how modern cybercrime increasingly operates through cooperative ecosystems where access brokers, social engineers, extortion actors, and ransomware affiliates may collaborate opportunistically rather than through permanent organizational structures.

2025: United Kingdom Retail Cybercrime Arrests

Arrests tied to UK retail cyberattacks demonstrated increasing international cooperation between law-enforcement agencies targeting identity-focused cybercrime operations. However, despite these enforcement actions, analysts observed continued operational activity linked to similar tactics and infrastructure. This reinforced the broader intelligence assessment that removing individual actors does not necessarily eliminate the underlying ecosystem enabling these attacks. The persistence of social-engineering-driven intrusions suggested that the operational model itself remained highly sustainable and easily reproducible.

2026: Continued SaaS Extortion and Ecosystem Persistence

By 2026, reporting continued to show activity involving SaaS extortion, cloud-platform abuse, and identity-system compromise linked to actors associated with the broader Scattered Spider ecosystem. The Buchanan guilty plea and related prosecutions provided additional evidence regarding recruitment patterns, online collaboration, and monetization strategies. At the same time, continued incidents demonstrated that law-enforcement pressure had not eliminated the operational methodology. Instead, the ecosystem adapted through rebranding, shifting partnerships, and tactical evolution, reinforcing the conclusion that Scattered Spider represents not only a single threat actor cluster but also a broader evolution in modern identity-centric cybercrime.

Law Enforcement, Disruption, and Prosecution Framework

Public law-enforcement activity between 2024 and 2026 changed the strategic environment around Scattered Spider. In November 2024, federal prosecutors in Los Angeles unsealed charges against five alleged members tied to phishing-text campaigns targeting employees at at least 12 companies. In August 2025, Noah Urban was sentenced to 10 years in prison, ordered to forfeit roughly \$4.8 million, and ordered to pay \$13 million in restitution. In September 2025, DOJ announced charges against a UK national, Thalha Jubair, alleging participation in approximately 120 intrusions, including 47 U.S.-based victims and more than \$115 million in ransom payments. In April 2026, Tyler Buchanan pleaded guilty in federal court to charges tied to phishing intrusions affecting at least a dozen companies and theft of at least \$8 million in virtual currency.

Prosecution and Disruption Table

Action	Date	Public significance
Five defendants charged in phishing-text scheme	November 2024	Demonstrated willingness to pursue Scattered Spider-linked conspiracies as a coordinated federal case
Noah Urban sentenced	August 2025	Showed that high-profile young English-speaking operators were prosecutable and punishable
Thalha Jubair charged	September 2025	Emphasized the scale of alleged victimization and ransom-linked harm

Action	Date	Public significance
Tyler Buchanan guilty plea	April 2026	Reinforced person-level accountability and the role of virtual-currency theft in the criminal model
UK arrests linked to retail attacks	July 2025	Showed operational disruption through cross-border law enforcement and domestic arrest activity

This enforcement picture indicates a maturing disruption model: person-focused cases, infrastructure tracing, device and account evidence, interagency cooperation, and cryptocurrency-linked forfeiture. The UK arrests associated with the retail incidents also demonstrate that tactical disruption and criminal investigation are no longer hypothetical responses; they are now part of the operating environment the actor must navigate.

The most important analytic lesson from these cases is that meaningful disruption requires more than domain takedowns or malware signatures. Scattered Spider's center of gravity is social and organizational, so personnel identification, communications records, infrastructure linkage, wallet tracing, and device-level evidence become unusually important. This favors a prosecution model that treats threat-actor labels as investigative aids, not final legal conclusions. In practice, that means building cases around named individuals, roles, wallets, login artifacts, infrastructure purchases, communications platforms, and concrete harms.

A useful disruption framework operates at three levels. At the **strategic** level, governments and platforms should degrade the enabling environment: SIM-swap brokerage, criminal credential markets, proxy services, fraudulent phone-number acquisition, and crypto cash-out paths. At the **operational** level, defenders and investigators should identify clusters of

targeting behavior against sectors and vendors, because Scattered Spider-style campaigns often move in waves rather than isolated single-victim episodes. At the **tactical** level, organizations must be able to freeze identity abuse fast: disable compromised authenticators, sever risky vendor paths, revoke sessions and OAuth grants, isolate virtualization control planes, and preserve logs for later legal use. That three-level framework is more aligned with the observed tradecraft than a narrow focus on malware-only indicators.

Mitigation Priorities, Intelligence Gaps, and Outlook

The most important defensive lesson is that organizations should redesign helpdesk and identity workflows under the assumption that the caller may be hostile and socially skilled. Password resets, MFA changes, and authenticator enrollment should require verified callback procedures, stronger proofing, supervisor approval for privileged identities, tightly logged exceptions, and where feasible a time delay or second-channel approval step. This is not an abstract recommendation. The public record shows repeatedly that Scattered Spider's most dangerous achievements begin when support processes are optimized for convenience instead of adversarial resistance.

The second priority is phishing-resistant MFA and stronger identity assurance. Okta's later reporting indicates that heavily targeted organizations increased adoption of phishing-resistant MFA after being exposed to Scatter Swine or Scattered Spider-style attacks. That is consistent with the broader evidence: voice and SMS-centered adversaries are strongest where OTPs, help-desk resets, and recovery channels remain weak. FIDO2, hardware-backed

authentication, passkeys, stricter recovery policy, and aggressive session review are not generic “best practices” in this context; they directly target the actor’s center of gravity.

The third priority is SaaS and cloud-governance discipline. GTIG’s 2025 and 2026 reporting on voice-phishing-led data extortion and ShinyHunters-branded SaaS theft shows how quickly compromised identities can pivot into malicious connected apps, token abuse, direct data export, and broad cloud exposure. Organizations should therefore continuously inventory OAuth grants and connected applications, enforce least privilege on SaaS integrations, monitor for unusual data-export volumes, and treat Snowflake, Salesforce, collaboration suites, and identity-provider logs as frontline telemetry rather than as secondary audit sources.

The fourth priority is resilience against hypervisor and recovery-denial impact. Because recent reporting links Scattered Spider-associated operations to DragonForce and ESXi encryption, organizations using VMware-heavy environments should isolate administrative identities, reduce transitive trust from identity platforms into virtualization management, enforce separate backup credentials, maintain immutable or offline backup options, and rehearse recovery under the assumption that both identity and virtual infrastructure controls may be compromised simultaneously. In effect, organizations should plan not just for stolen data but for stolen control.

Control Alignment Table

Observed actor behavior	Defensive control	Why the control is directly relevant
Help-desk impersonation	Verified callbacks, supervisor approval, stronger proofing	Breaks the actor's preferred initial-access path
SMS and voice phishing	Phishing-resistant MFA, OTP retirement where possible	Reduces effectiveness of smishing/vishing and MFA manipulation
Vendor-path abuse	Shared identity assurance requirements for contractors and MSPs	Closes one of the most repeatedly exploited trust relationships
SaaS data targeting	OAuth governance, token review, export monitoring	Detects and constrains post-compromise cloud abuse
RMM and valid-account misuse	Privileged-session monitoring and just-in-time access	Makes "living off the land" administration more visible
ESXi / hypervisor impact	Backup isolation, vCenter hardening, recovery rehearsals	Limits the actor's ability to convert access into enterprise disruption

The logic of the table is straightforward: each control is mapped to a public, repeatedly observed Scattered Spider behavior rather than to an abstract maturity checklist.

Intelligence Gaps and Limitations

Several important limitations remain. Public actor attribution for some marquee incidents, especially the MGM intrusion and portions of the M&S narrative, still depends in part on source-based reporting and third-party analysis rather than on full victim-side technical disclosure. The “Trinity of Chaos” storyline and similar coalition narratives are analytically relevant, but they are not corroborated at the same level as government advisories, SEC filings, or formal law-enforcement cases. Likewise, the public record clearly establishes the centrality of cryptocurrency to the criminal business model, but it does not yet provide a sufficiently detailed laundering map to support highly specific public claims beyond general off-ramping inference. Finally, the public record almost certainly undercounts incidents because identity-centric intrusions can be contained quietly or disclosed in generalized terms that obscure the initial-access mechanism.

Forecast

The most plausible near-term outlook is continued persistence and adaptation of Scattered Spider-style operations even if directly attributable activity temporarily declines due to arrests, indictments, or increased international law-enforcement pressure. Public prosecutions and guilty pleas may disrupt specific operators and force tactical adjustments, but the broader ecosystem that enables these attacks remains active and resilient. The operational model used by Scattered Spider does not depend on highly specialized malware development or centralized infrastructure. Instead, it relies on transferable social-engineering expertise, identity compromise techniques, publicly available remote-access tools, and decentralized collaboration networks. As

long as these underlying conditions remain present, similar operations are likely to continue regardless of whether individual members are removed from the ecosystem.

The structure surrounding Scattered Spider also suggests that future activity may become increasingly fragmented and difficult to attribute with confidence. Members and affiliates can rapidly shift aliases, communication platforms, and operational partnerships following public exposure or law-enforcement intervention. This creates an environment where activity may continue under new branding, temporary coalitions, or loosely affiliated extortion partnerships rather than under a single consistent identity. Reporting surrounding overlap with groups such as UNC3944, ShinyHunters, LAPSUS\$, and broader communities associated with “The Com” demonstrates how modern cybercriminal ecosystems operate more as fluid networks than traditional hierarchical organizations. The reported emergence of collaborative narratives such as the so-called “Trinity of Chaos” further reinforces the possibility that future campaigns will involve temporary alliances between multiple threat actors sharing infrastructure, access, or extortion resources.

Organizations should therefore expect recurring sector-specific waves of intrusion activity, particularly in industries where operational urgency, customer-facing support functions, and outsourced identity verification processes create ideal conditions for trust exploitation. Hospitality, retail, telecommunications, insurance, financial services, cloud infrastructure, logistics, and software-as-a-service environments are likely to remain especially vulnerable because these sectors depend heavily on remote authentication systems, third-party support personnel, and rapid customer-service workflows. Threat actors understand that environments prioritizing speed and convenience frequently contain procedural weaknesses that can be

manipulated through impersonation, MFA fatigue attacks, SIM swapping, and help-desk social engineering.

Cloud identity systems and SaaS platforms will likely remain among the highest-priority targets moving forward. Enterprise dependence on centralized identity providers creates a situation where compromise of a single privileged account can provide broad access across multiple business functions simultaneously. This trend increases the strategic value of identity-focused attacks and reduces the need for traditional malware deployment. Rather than exploiting technical vulnerabilities directly, future Scattered Spider-style campaigns will likely continue emphasizing credential theft, session hijacking, token abuse, and exploitation of legitimate administrative tools already trusted within enterprise environments. This “living off the land” approach complicates detection because malicious activity often appears operationally similar to normal user behavior.

Another likely development is increased specialization within the ecosystem itself. Some operators may increasingly focus on initial access acquisition through social engineering and credential compromise, while affiliated groups handle data exfiltration, extortion negotiations, or ransomware deployment. This division of labor mirrors broader ransomware-as-a-service trends observed elsewhere in the cybercrime landscape and would allow Scattered Spider-affiliated actors to scale operations without requiring every participant to possess advanced technical capabilities. Because social engineering remains relatively low-cost and highly scalable, it lowers the barrier to entry for new participants and enables rapid regeneration of operational capacity after disruptions.

The financial model associated with these operations is also likely to remain viable soon. Data extortion continues to create strong leverage against victim organizations because the

consequences of public disclosure often extend far beyond immediate operational disruption. Regulatory penalties, reputational damage, shareholder concerns, customer notification requirements, and litigation risk all increase pressure on organizations to negotiate. Even in environments where ransomware encryption is absent, the theft and threatened release of sensitive information can produce sufficient coercive leverage to generate substantial financial returns for threat actors.

From a defensive perspective, the forecast strongly indicates that organizations can no longer frame cybersecurity primarily as a malware or perimeter-defense problem. The operational success of Scattered Spider demonstrates that trust relationships, identity systems, and human decision-making processes now represent some of the most critical attack surfaces within modern enterprises. Organizations that continue prioritizing only endpoint security, antivirus solutions, or traditional intrusion detection while neglecting identity governance and procedural security will remain disproportionately exposed.

The most effective long-term response is therefore organizational as much as technical. Enterprises will need to harden identity infrastructure, enforce phishing-resistant authentication methods, strengthen help-desk verification procedures, reduce implicit trust assumptions involving vendors and contractors, aggressively monitor SaaS and cloud-platform abuse, and improve behavioral analytics capable of identifying anomalous use of legitimate accounts. Investment in security-awareness training must also evolve beyond generic phishing education toward realistic simulations of vishing, impersonation, and social-engineering scenarios targeting support personnel and privileged users.

Ultimately, Scattered Spider should be understood not simply as a single cybercriminal group, but as a representation of a broader evolution in financially motivated cybercrime. Its

defining capability is the conversion of trust, identity, and ordinary business processes into privileged access and strategic leverage. That operational model is highly adaptive, comparatively inexpensive to sustain, and difficult to eliminate through arrests alone. As long as organizations continue relying on centralized identity systems, distributed support operations, and rapid-access workflows, threat actors employing Scattered Spider-style tradecraft will likely remain a persistent and significant threat within the global cyber landscape.

References

CrowdStrike. (2023). Scattered Spider: Analyzing UNC3944's social engineering operations.

CrowdStrike Intelligence. <https://www.crowdstrike.com>

Federal Bureau of Investigation. (2023). Cybercriminal actors use social engineering to compromise corporate networks. <https://www.fbi.gov>

Google Cloud Security. (2023). UNC3944 (Scattered Spider) threat analysis report. Google Threat Intelligence Group. <https://cloud.google.com>

Microsoft Threat Intelligence. (2023). Storm-0875 / Scattered Spider: Identity-based attacks and defense evasion. Microsoft Security Blog. <https://www.microsoft.com/security/blog>

Mandiant (Google Cloud). (2023). UNC3944: Targeting identity systems through social engineering. <https://www.mandiant.com>

CISA. (2023). Scattered Spider and social engineering threats to enterprise environments. Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov>

Verizon. (2024). Data Breach Investigations Report (DBIR). Verizon Enterprise. <https://www.verizon.com/business/resources/reports/dbir/>

IBM Security. (2024). Cost of a Data Breach Report. IBM. <https://www.ibm.com/security/data-breach>

Krebs, B. (2023). Inside the MGM Resorts cyberattack. Krebs on Security. <https://krebsonsecurity.com>

Reuters. (2023). MGM Resorts' cyberattack disrupts operations across properties. <https://www.reuters.com>

Bloomberg. (2023). Caesars paid ransom after cyberattack linked to Scattered Spider.

<https://www.bloomberg.com>

Chainalysis. (2024). Crypto crime report: Ransomware and extortion trends.

<https://www.chainalysis.com>

Europol. (2023). Internet Organized Crime Threat Assessment (IOCTA).

<https://www.europol.europa.eu>

ENISA. (2023). Threat landscape report: Social engineering attacks. European Union Agency for Cybersecurity. <https://www.enisa.europa.eu>

NIST. (2020). Digital identity guidelines (SP 800-63). National Institute of Standards and Technology. <https://www.nist.gov>

Appendices

Appendix A

ACH Matrix

	A	B	C	D
1	Hypothesis	Supporting Evidence	Contradicting Evidence	Final Judgment
2	Scattered Spider is a distinct actor cluster inside a wider cybercriminal ecosystem	Consistent social engineering tradecraft including SIM swapping, MFA fatigue, vishing, and help-desk impersonation across incidents; repeated attribution by CrowdStrike, Mandiant, Microsoft, FBI, and CISA; operational continuity in MGM, Caesars, and cloud-service intrusions; overlap with 'The Com' ecosystem while maintaining recognizable TTPs.	Decentralized membership, changing aliases, and varying operational sophistication create attribution challenges and blur organizational boundaries.	Most Likely
3	Scattered Spider has merged into a durable cartel with LAPSUS\$ and ShinyHunters	Shared ecosystem participation, overlapping aliases in reporting, similar extortion and identity-compromise methods, and collaboration narratives within underground communities.	No verified evidence of a permanent merged hierarchy, centralized leadership structure, or unified operational command.	Possible but Not Demonstrated
4	Scattered Spider is primarily a media-created catch-all label with little analytic coherence	Shared TTPs such as credential theft and social engineering are common among many financially motivated actors; underground disinformation complicates attribution.	Government agencies, cybersecurity vendors, and incident responders consistently track a recognizable operational cluster with recurring tactics, victimology, and behavioral patterns.	Least Likely

Appendix B

Persona and Behavioral Assessment

The Ezra Weiss persona supported the investigation by reinforcing a cautious, intelligence-driven approach focused on observation, verification, and behavioral analysis rather than unnecessary risk-taking. Ezra's methodical and technology-focused background aligned closely with the requirements of investigating Scattered Spider, particularly its reliance on social engineering, identity compromise, and trust exploitation. The persona helped frame the investigation around human behavior, OSINT collection, attribution caution, and long-term pattern analysis, which improved the overall realism and consistency of the assessment.

Appendix C

	Partnership with BreachForums and TeamPCP Greetings, Breached[.]st community. Today marks a historic moment for the underground community. We, the Vect Ransomware Organization, are proud to officially announce our partnership with BreachForums, the strongest and most respected hacking community in history. This is the beginning of... vect Thread Wednesday at 8:54 PM Replies: 32 Forum: Announcements
	I'm hiring negotiators, might be your chance to get rich session 05e76e93cbde534a11e3916352b8be977050a05bf63e879780c8a2e8e2a8d50036 vect Post #6 Mar 18, 2026 Forum: Services
	I'm hiring negotiators, might be your chance to get rich send a dm vect Post #4 Mar 17, 2026 Forum: Services
	I'm hiring negotiators, might be your chance to get rich If you have a phone, and know about anonymity, and can speak English, we will hire you as a negotiator you will get 5% of every paid ransom you negotiate contact me here in the forum for more details vect Thread Feb 27, 2026 Replies: 5 Forum: Services
	IntelBroker's Endurance Malware no, this is a vibe coded peace of trash that can be coded in 5 lines, don't bother vect Post #2 Feb 24, 2026 Forum: Programming
	we buy your VPN 0days If you have a 0day in a services or any other platforms that can be used for Initial access we will buy them from you vect Thread Feb 23, 2026 Replies: 1 Forum: Buyers Place
	Vect v2 update Vect v2 - Released February 14, 2026 We are pleased to announce the release of our latest ransomware builder version. This update introduces significant improvements in performance, compatibility, and operational capabilities, with triple-extortion tactics now fully integrated as standard. We... vect Thread Feb 13, 2026 Replies: 1 Forum: Services

Appendix D

